

			
Review	Interview	Inspection	Observation
Reviewing documentation such as policy, standards, and procedures is the most common evidence-gathering technique. It is generally the first task of the CCSSA to help ascertain the people, processes, and technology components of an information system and ISMS that are in scope for the CCSS audit. NOTE: concern should be raised by both the CCSSA and CCSSA-PR if an audited entity points to external documentation as their policy or standard. For example, an audited entity points to an open-source configuration guide on the project website for a mechanism or library as their standard. This should not be acceptable as the audited entity should ensure that internal documentation exists and not rely on external documentation outside their control. a. A Policy is a document that defines the goals or "mission" of the entity, such as "we provide a secure environment for our customers to transact." b. A Standard is a document that will outline the best practices, based on internationally recognized standards, as to how the entity will meet this goal, such as "the entity implements strong access control mechanisms that conform to ISO27001 or NIST 800-53" and another example "the entity uses an HSM certified to FIPS 140-3." c. A Procedure is a document that defines exactly how a goal is to be achieved. A procedure document will list the steps or tasks involved to achieve a result. For example, a procedure document can be used to onboard a new customer or configure a new HSM.	Interviewing personnel responsible for and managing the in-scope systems is a vital evidence-gathering technique for a CCSSA. Interviewing personnel can highlight key information that is never located within written documentation, such as how work is really done- sometimes known as "Shadow IT." The key focus of interviewing personnel is understanding if the person interviewed is following the entity's policy/standards/procedures or deviating from these. Deviations will concern the CCSSA and the entity, as there will not be any oversight or control of what is actually being done and could introduce vulnerabilities into the in-scope environment.	Inspection is an evidence-gathering technique where the CCSSA inspects system configurations and other technology components to ensure that configuration requirements stated in the standards and procedure documents have been implemented. For example, the entity states in their access control standard that all access into the in-scope environment must use MFA. The CCSSA should inspect the access control systems to ensure MFA has been implemented, configured correctly, and applied to all user accounts with access to the in-scope environment. Inspection is a "trust but verify" approach to auditing where the documentation and interviewees state a specific action has been taken, but the auditor needs to verify by inspecting the system.	Observing a process being undertaken is another important evidence-gathering technique along the same lines as inspection: trust but verify. The CCSSA, if possible, should observe the processes being undertaken to ensure they meet the documented processes. For example, the CCSSA can observe personnel reviewing audit log files from in-scope systems or the process of adding a new user account to a system. When observing a process is impractical, such as asking the audited entity to undertake a key creation ceremony in production, the auditor should instead ask the personnel to discuss the steps that would be taken.

CCSS v9 Testing Procedures

Requirement #	Requirement	Review		Inspect	Observe	Interview	Additional Guidance
		Policy, Standards, Procedures (PSP)	Business As Usual (BAU)				
1.01.1.1	Key material is generated by the actor who will be using it.	The CCSSA will review key management policies, standards and procedures for the generation of key material to ensure key material is generated by the actor who will use the key material.	The CCSSA will review records of the key material generation process, sometimes referred to as "key ceremony report" to ensure the key material is generated by the actor who will use it. NOTE: BAU records for the generation of key material are not expected for key material generated for one transaction, such as a wallet address created once for a deposit of funds into a customer's account.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	The CCSSA will request a demonstration of the key material generation process to ensure that the actor generating the key material will be the actor using the key material. Note requirement 1.01.1.2 as an exception.	The CCSSA will interview personnel involved in the generation of key material to ensure that the policies and procedures for the generation of key material are followed.	
1.01.1.2	Where an automated signing agent will use key material, and the place of generation of key material is different from the place of use. The following criteria are addressed: 1. The key material is generated within a secure Key Management System that meets applicable CCSS requirements. 2. The key material is transferred securely to the automated signing agent from the place of generation that meets applicable CCSS requirements. 3. The key material is securely removed from the place of generation that meets applicable CCSS requirements.	The CCSSA will review key management policies, standards, and procedures for the generation of key material to ensure this requirements criteria is addressed.	The CCSSA will review records of the key material generation process, sometimes referred to as a "key ceremony report" to ensure this requirements criteria is addressed. NOTE: BAU records for the generation of key material are not expected for key material generated for one transaction, such as a wallet address created once for a deposit of funds into a customer's account.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	The CCSSA will request a demonstration of the key material generation process to ensure that the actor generating the key material will be the actor using the key material. Note requirement 1.01.1.2 is an exception.	The CCSSA will interview personnel involved in the generation of key material to ensure that the policies and procedures for the generation of key material are followed.	
1.01.1.3	A digital signature for the key material generation mechanism is generated, published, and validated prior to each execution.	The CCSSA will review key management policies, standards, and procedures for the generation of key material to ensure a digital signature is generated, published and validated prior to each execution.	The CCSSA will review records of the key material generation process, sometimes referred to as "key ceremony report". The report should contain confirmation that the key material generation mechanism software was validated before use.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	The CCSSA will request a demonstration of the validation process to ensure key material creation policies, standards, and processes are followed.	The CCSSA will interview personnel involved in the validation process to ensure key material creation policies, standards and processes are followed.	
1.01.2.1	The methodology for generating key material is validated prior to use. Software does not include features that restrict which values can be used. Software does not include features that store or transmit data to another actor, unless that feature enhances security.	The CCSSA will review key management policies, standards, and procedures for the generation of key material to ensure that software used for key management processes is validated prior to use and does not include features that will restrict the security of the functions and mechanisms for generating key material or transmitting or storing key material to another actor.	The CCSSA will review records of the key material generation process, sometimes referred to as "key ceremony reports." The report should confirm that the key material generation mechanism methodology was validated before use.	The CCSSA will inspect the configuration of the key material generation mechanism to ensure the configuration parameters and values do not impact the security of the key material generation process.	The CCSSA will request a demonstration of the validation process to ensure key material creation policies, standards, and processes are followed.	The CCSSA will interview personnel involved in the validation process to ensure key material creation policies, standards, and processes are followed.	
1.01.2.2	In cases where key material is generated without the use of software, the generation methodology is validated to ensure determinism is not present.	The CCSSA will review key management policies, standards, and procedures for the generation of key material to ensure that non-digital key material generation methodology does not introduce determinism in the key material generation process.	The CCSSA will review records of the key material generation process, sometimes referred to as a "key ceremony report" to ensure no determinism was present during the key material generation process. For this requirement, the considerations should also be addressed and documented in the key ceremony report. NOTE: BAU records for the generation of key material are not expected for key material generated for one transaction, such as a wallet address created once for a deposit of funds into a customer's account.	The CCSSA will inspect the non-digital mechanisms used to generate key material to ensure key material creation policies, standards, and processes are followed.	The CCSSA will request a demonstration of the usage of the non-digital mechanism used to generate key material to ensure key material creation policies, standards, and processes are followed.	The CCSSA will interview personnel involved in the generation of key material to ensure key material creation policies, standards and processes are followed.	
1.01.3.1	The generation mechanism for key material conforms to NIST SP 800-90A.	The CCSSA will review key management policies, standards, and procedures for the generation of key material to ensure that the mechanisms that generate key material conform to NIST SP 800-90A.	The CCSSA will review records of the key material generation process, sometimes referred to as a "key ceremony report". The CCSSA will review the reports to ensure the process conforms to NIST SP 800-90A.	The CCSSA will inspect the configuration of the key material generation mechanism to ensure that the configuration parameters and values conform to NIST SP 800-90A. The CCSSA will inspect the configuration of the key material generation mechanism to ensure that the configuration parameters and values conform to NIST SP 800-90A.	The CCSSA will request a demonstration of the key material generation process to ensure the process conforms to NIST SP 800-90A.	The CCSSA will interview personnel involved in the generation of key material to ensure key material creation policies, standards, and processes are followed.	
1.01.3.2	Requirement: The key material generation process has been documented and addresses the following: 1. The key material generation process must be conducted in a secure environment. 2. The physical environment that will be used for the key material generation process is checked before use for any unauthorized recording/surveillance equipment, windows allowing the key material generation process to be viewed by external personnel, poor physical separation of the area from the main working areas, effective physical access controls to restrict unauthorized access of personnel, backup power supply, environmental controls to protect against electromagnetic interference, sound leakage, or other vulnerabilities that could compromise the process. 3. All equipment and software used for the key material generation process must be checked before use for updates such as new software versions, any signs of tampering, and be in good working order. 4. All moveable equipment such as hardware devices, laptops, and key material is secured from unauthorized access when not in use. 5. A detailed runbook defines all steps performed during the key material generation process. After the completion of each step, the participating actors sign off in the runbook stating that the step was performed and checked. 6. All roles participating in the key material generation process must be defined and utilized. Segregation of duties must be considered when allocating personnel to roles. 7. Each actor involved in the key material generation process must independently generate their own discrete key material. In a multi-signer scheme, no single actor is permitted to generate key material that will be used by another actor unless the actor is an automated signing agent. (Refer to requirements 1.01.1.1 and 1.01.1.2.)	The CCSSA will review key management policies, standards, and procedures for the creation of key material to ensure the criteria for this requirement is addressed.	The CCSSA will review pre-generation checklists or equivalent that address criteria two, three, and four of this requirement and also requirement 1.01.1.3. A key material generation "runbook" or equivalent must address: Details of the participants, such as the names, roles, and contact information of the individuals involved, such as key custodians, witnesses, and auditors. Purpose of the key material ceremony such as the generation, activation, backup, or destruction of key material. A step-by-step account of the actions taken during the ceremony, including the use of non-digital mechanisms to generate key material. Details of the hardware and software utilized during the ceremony, including serial numbers and configurations. Information about the key material generated, such as key type, size, seed, and purpose (without revealing sensitive key material information). Description of the security controls in place to ensure the integrity and confidentiality of the process. The signatures of participants and witnesses affirming their roles and agreement that the ceremony was conducted according to the defined protocols. Date and time of the ceremony.	The CCSSA will inspect the devices and systems used for key material generation to ensure they are patched and that all critical security patches are applied no later than one month after the patch(s) are released.	The CCSSA may want to observe the physical controls and environment where key material is generated either via a remote video call or while onsite. The CCSSA will request a demonstration of the key material generation process to ensure all criteria for this requirement are met.	The CCSSA will interview personnel involved in the key material generation process.	
1.01.4.1	Key material is generated on a Key Management System with sufficient entropy to ensure key material is not generated with any bias towards a reduced range of values, or other deterministic properties.	The CCSSA will review key management policies, standards, and procedures for the generation of key material that sufficient entropy is required when generating key material.	The CCSSA will review records of the key material generation process, sometimes referred to as a "key ceremony report," to ensure key material creation policies, standards and processes are followed.	The CCSSA will inspect the key material generation mechanism to ensure the entropy sources comply with this requirement. For guidance, the CCSSA may consult NIST 800-90B or equivalent.	The CCSSA will request a demonstration of the key material generation process to ensure the entropy sources meet the intent of this requirement.	The CCSSA will interview personnel involved in the generation of key material to ensure key material creation policies, standards, and processes are followed.	

CCSS v9 Testing Procedures							
Requirement #	Requirement	Review		Inspect	Observe	Interview	Additional Guidance
		Policy, Standards, Procedures (PSP)	Business As Usual (BAU)				
1.02.1.1	When considering the application of a single-signer mechanism to a wallet, the following criteria are addressed: 1. The criticality of the wallet to the CCSS Trusted Environment. 2. The impact of loss of customer funds controlled by the wallet. 3. The risk of a wallet compromise is included in the threat model defined in requirement 2.03.2.1. 4. The effectiveness of the security controls implemented to protect the wallet.	The CCSSA will review key management policies, standards, and procedures for the generation of a wallet to ensure that any consideration of using a single-signer mechanism must address the criteria within this requirement.	The CCSSA will review records of the generation of a wallet using a single-signer mechanism and ensure that all criteria for this requirement have been addressed and recorded in writing.	Inspection for this requirement is optional; may be used at the CCSSA's discretion.	Observation for this requirement is optional; may be used at the CCSSA's discretion.	The CCSSA will interview personnel involved in the generation of a wallet to ensure this requirement's criteria are addressed when the entity considers using a single-signer mechanism.	Review penetration test reports -- addresses point 4 Review Key Inventory- addresses criteria 1 Review Risk Assessment Report- addresses criteria 2 and 3
1.02.2.1	A wallet that has implemented a multi-signer mechanism has at least one redundant key for recovery purposes.	The CCSSA will review key management policies, standards, and procedures for the generation of a wallet to ensure redundant key material is required for wallets that implement a multi-signer mechanism.	The CCSSA will review records of the generation of a wallet to ensure there is redundant key material or equivalent that has been configured for the wallet.	The CCSSA will inspect the wallet generation mechanism configurations to ensure that there are no restrictions on the ability to assign redundant key material or equivalent to a wallet.	The CCSSA will request a demonstration of the wallet generation process to ensure redundant key material or equivalent is configured for a wallet.	The CCSSA will interview personnel involved in the generation of a wallet to ensure redundant key material or equivalent is generated for a wallet.	Backup processes and procedures documentation may provide additional information
1.02.3.1	Key materials for a wallet that implements a multi-signer mechanism are stored in different locations.	The CCSSA will review key management policies, standards, and procedures for the generation of a wallet to ensure risks of storing key material in the same location are addressed.	The CCSSA will review records of the generation of a wallet to ensure that key material for a wallet that implements a multi-signer mechanism is stored in different locations.	The CCSSA will inspect the logical locations where key material has been recorded as stored to ensure key material for a wallet that has implemented a multi-signer mechanism is stored in different locations. The CCSSA may decide to inspect the physical locations where key material has been recorded as stored to ensure key material for a wallet that has implemented a multi-signer mechanism is stored in different locations.	The CCSSA will request a demonstration of the wallet generation process to ensure that if the wallet implements a multi-signer mechanism, it includes distributing key material to different locations.	The CCSSA will interview personnel involved in the generation of a wallet to ensure risks of storing key material in the same location are addressed.	
1.02.4.1	Key material for a wallet that implements a multi-signer mechanism is stored by distinct operators within the entity or separate entities.	The CCSSA will review key management policies, standards, and procedures for the generation of a wallet to ensure this requirement has been addressed.	The CCSSA will review records of the generation of a wallet to ensure that key material for a wallet that implements a multi-signer mechanism are stored by distinct operators if applicable. NOTE: The use of an automated signing agent needs to be considered when addressing this requirement hence the use of "if applicable."	The CCSSA will inspect the logical locations where key material has been recorded and stored to ensure that distinct operators control key material for a wallet that has implemented a multi-signer mechanism. The CCSSA may decide to inspect the physical locations where key material has been recorded as stored to ensure that distinct operators control key material for a wallet that has implemented a multi-signer mechanism.	The CCSSA will request a demonstration of the wallet generation process to ensure the process includes distributing key material to distinct operators if the wallet implements a multi-signer mechanism.	The CCSSA will interview personnel involved in the generation of a wallet to ensure this requirement has been addressed.	NOTE: The use of an automated signing agent needs to be considered when addressing this requirement.
1.02.5.1	The entity has a documented policy in place which details the company's internal policies and procedures and covers the relevant areas of wallet generation.	The CCSSA will review key management policies, standards, and procedures for the generation of a wallet.	The CCSSA will review wallet generation records to ensure that the generation of a wallet follows the defined policies, standards, and procedures.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	The CCSSA will request a demonstration of the wallet generation process to ensure the process follows the documented policies and procedures for wallet generation.	The CCSSA will interview personnel involved in the generation of a wallet to ensure the process follows the documented policies and procedures for wallet generation.	

CCSS v9 Testing Procedures							
Requirement #	Requirement	Review		Inspect	Observe	Interview	Additional Guidance
		Policy, Standards, Procedures (PSP)	Business As Usual (BAU)				
1.03.1.1	Key material is stored with the use of strong encryption when not in use.	The CCSSA will review key management policies, standards and procedures for requiring and ensuring operational key material is encrypted when not in use.	The CCSSA will review key material generation records to ensure operational key material is encrypted when not in use.	The CCSSA will inspect the storage mechanism configurations that store the operational key material to ensure the configurations meet the defined policy, standards, and procedures.	Observation for this requirement is optional; may be used at the CCSSA's discretion.	The CCSSA will interview personnel responsible for ensuring that operational key material is encrypted when not in use.	
1.03.2.1	A backup(s) of the operational key material exists.	The CCSSA will review key management policies, standards and procedures for requiring and ensuring operational key material is backed up.	The CCSSA will review key material backup records to ensure operational key material is backed up.	The CCSSA will inspect the backup mechanism configurations that store the backup of the operational key material to ensure the configurations meet the defined policies, standards, and procedures. The CCSSA will inspect the storage containers that store the backup of the operational key material to ensure backups of the operational key material exist.	The CCSSA will request a demonstration of the backup process for operational key material to ensure operational key material is backed up correctly.	The CCSSA will interview personnel who are responsible for backing up operational key material to ensure that backups are performed.	
1.03.2.2	A backup(s) exists for all key material used in the wallet. The backup can take any form (e.g., paper, digital, metal).	The CCSSA will review key management policies, standards and procedures for requiring and ensuring all key material is backed up.	The CCSSA will review key material backup records to ensure all key material is backed up.	The CCSSA will inspect the backup mechanism configurations that store the backup of all key material to ensure the configurations meet the defined policies, standards, and procedures. The CCSSA will inspect the storage containers that store the backup of all key material to ensure backups of the operational key material exist.	The CCSSA will request a demonstration of the backup process for operational key material to ensure all key material is backed up.	The CCSSA will interview personnel who are responsible for the backup of key material.	
1.03.3.1	The backup(s) is protected against environmental risks.	The CCSSA will review key management policies, standards and procedures for requiring and ensuring all backups containing key material are protected from environmental risks.	The CCSSA will review relevant certification records for premises that store key material backups, such as certifications covering the inspection and certification of building fire protection controls, earthquake protection, and electrical surge protection.	For backups containing key material stored in physical containers such as bank safes, safe deposit boxes, and other physical storage facilities, the CCSSA will inspect the controls that protect the physical backups to ensure the backups are protected from environmental risks.	Observation for this requirement is optional; may be used at the CCSSA's discretion.	The CCSSA will interview personnel who are responsible for the backup of key material to ensure that environmental risks are identified and addressed.	

CCSS v9 Testing Procedures							
Requirement #	Requirement	Review		Inspect	Observe	Interview	Additional Guidance
		Policy, Standards, Procedures (PSP)	Business As Usual (BAU)				
1.03.3.2	The backup(s) of key material is stored in a geographically separate location(s) from the storage and usage of operational key material.	The CCSSA will review key management policies, standards and procedures for requiring and ensuring all backups containing operational key material are stored in geographically separate locations from the operational key material.	The CCSSA will review the key material inventory, or other relevant BAU records that show backups containing operational key material are not stored in the same geolocation as the storage of operational key material.	For backups containing key material that are electronically stored, such as on a backup server, the CCSSA will inspect the storage areas to ensure that the backups are not stored in the same geolocation as the operational key material. For backups containing key material that are electronically stored, such as on a backup server, inspect the mechanism responsible for backing up the operational key material and storing the backup in the storage container. The CCSSA may request to inspect physical containers such as bank safes, safe deposit boxes, and other physical storage facilities to ensure all recorded physical backups are present or in transit to or from the physical storage facility.	Observation for this requirement is optional; may be used at the CCSSA's discretion.	The CCSSA will interview personnel who are responsible for the backup of key material to ensure backups containing operational key material are not stored in the same geolocation as operational key material.	Under Inspection: The CCSSA may request to inspect physical containers, including bank safes and safe deposit boxes, to verify that all recorded physical backups are stored at the disaster recovery site (DR site).

CCSS v9 Testing Procedures							
Requirement #	Requirement	Review		Inspect	Observe	Interview	Additional Guidance
		Policy, Standards, Procedures (PSP)	Business As Usual (BAU)				
1.03.4.1	The backup(s) is protected by access controls that prevent unauthorized parties from accessing it.	The CCSSA will review key management and access control policies, standards, and procedures to ensure access control, including the use of the least privilege and need-to-know principles, is required for backups containing operational key material.	If the backup media is physical, such as removable electronic media, paper, wood or metal, the CCSSA will review the following: 1. The list of personnel with access to key material and the codes/passwords/physical keys used to access the backup media (safe, locked drawer, etc...). 2. The access log mechanism that records all access to the backup. Access log records must contain: (a) the full name of the person who accessed the backup, (b) the date and time of access, (c) the reason for accessing the backup and (d) written management approval to access the backup. 3. Check if the backups containing key material can be sent to another premise, such as third-party premises. If they are sent, review the process for sending them. A written log recording the movement and authorization to transport the backup must be kept. The transportation mechanism of the backup media should allow for complete tracking while in transit. 4. If CCTV is present to monitor the location of the backup media, then review the CCTV video footage to ensure it is working correctly and retaining video records. If the backup is stored electronically, the CCSSA will review the following: 1. The list of personnel with access to the backups. 2. The access log mechanism that records all access to the backup. The access log records must contain: (a) the full name of the person who accessed the backup, (b) the date and time of access, (c) the reason for accessing the backup and (d) written management approval to access the backup.	If the backup media is physical, such as removable electronic media, paper, wood or metal, the CCSSA may inspect the following: 1. The access controls that protect the physical backups such as locked rooms/cabinets/containers, door access controls, locks and CCTV. If the backup is stored virtually, the CCSSA will inspect the following: 1. The access control mechanism configurations to ensure that only authorized personnel can access the backup files. 2. The user accounts with access to the backup files to ensure only personnel with roles required to access backup files have access.	If the backup media is physical, such as removable electronic media, paper, wood or metal, the CCSSA may observe the following: 1. The physical locations storing backup media to ensure physical access controls have been implemented. 2. The location of any codes/passwords/physical keys of the backup media (safe, locked drawer, etc...) to ensure physical access controls have been implemented. 3. The transportation process of the backup media if moved between locations. If the backup is stored electronically, the CCSSA will observe the following: 1. Personnel accessing the backup files to ensure access controls have been implemented.	The CCSSA will interview personnel who are responsible for access control to the backups containing operational key material to ensure that effective access controls are implemented.	

CCSS v9 Testing Procedures							
Requirement #	Requirement	Review		Inspect	Observe	Interview	Additional Guidance
		Policy, Standards, Procedures (PSP)	Business As Usual (BAU)				
1.03.5.1	The backup(s) implements some form of tamper-evident mechanism that allows an operator to determine if it has been accessed.	The CCSSA will review key management and access control policies, standards, and procedures to ensure mechanisms that detect and record attempted access of a backup are required for backups containing operation key material.	If the backup media is physical, such as removable electronic media, paper, wood or metal, the CCSSA will review the following: 1. The CCSSA will review the key material inventory or other relevant BAU records that show backups containing operational key material are stored within a tamper-evident mechanism, such as a tamper-evident container. If the backup is stored electronically, the CCSSA will review the following: 1. Any alerts generated by the mechanism configured to monitor and alert on access to the electronic backups.	If the backup media is physical, such as removable electronic media, paper, wood or metal, the CCSSA may inspect the following: 1. The tamper-evident mechanism used to store the backup containing operational key material to ensure the tamper evident mechanism meets industry specification requirements. If the backup is stored electronically, the CCSSA will inspect the following: 1. The logical security control configurations that detect and alert on access attempts to the backups containing operational key material to ensure the security control is configured correctly.	If the backup media is physical, such as removable electronic media, paper, wood or metal, the CCSSA may observe the following: 1. The physical backup to ensure the backup media is stored within a tamper-evident mechanism. If the backup is stored electronically, the CCSSA will observe the following: 1. Personnel attempting to access the backup to observe the mechanism monitoring the backups generating alerts for the attempted access.	The CCSSA will interview personnel who are responsible for ensuring that backups containing operational key material are protected by a tamper-evident mechanism.	For example, tamper-evident bags that indicatetampering...
1.03.6.1	Backups of key material are stored with the use of strong encryption that is equal or greater to the security prescribed for the operational key material.	The CCSSA will review key management policies, standards, and procedures to ensure the electronic backup(s) containing operational key material is encrypted with strong encryption.	The CCSSA will review key material backup records to ensure all key material is encrypted with strong encryption.	The CCSSA will inspect the backup mechanism configurations to ensure backups are encrypted with strong encryption.	The CCSSA will request a demonstration of the backup process for operational key material to ensure operational key material is encrypted as part of the backup process.	The CCSSA will interview personnel who are responsible for ensuring that backups containing operational key material are encrypted.	

CCSS v9 Testing Procedures							
Requirement #	Requirement	Review		Inspect	Observe	Interview	Additional Guidance
		Policy, Standards, Procedures (PSP)	Business As Usual (BAU)				
1.04.1.1	The entity maintains checklists that cover all tasks that are completed when personnel vacate or transition into key holder roles within the entity. These checklists have been reviewed by knowledgeable personnel to ensure "least privilege principles" are applied to the system, as well as necessary access where required.	The CCSSA will review access management policies, standards, and procedures to ensure grant and revoke processes are documented.	The CCSSA will review grant and revoke request documentation to ensure that the documented processes are followed.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	The CCSSA will request a demonstration of the grant and revoke processes to ensure the policies, standards, and procedures are followed.	The CCSSA will interview personnel responsible for the grant and revoke processes to ensure that the documented policies, standards, and procedures are followed.	
1.04.2.1	All key holder grant/revoke requests are conducted over Approved Communication Channels.	The CCSSA will review access management policies, standards, and procedures to ensure grant and revoke processes are only requested and accepted using approved communication channels.	The CCSSA will review grant and revoke request documentation to ensure that only approved communications are used.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	The CCSSA will request a demonstration of the grant and revoke processes to ensure only approved communication channels are used.	The CCSSA will interview personnel who are responsible for the grant and revoke access processes to ensure only approved communication channels are used.	
1.04.3.1	The entity's checklists include auditing information that record the identity of personnel that perform the grant/revoke operations. Each entry within the audit trail is attested to by personnel who performed that task.	The CCSSA will review access management policies, standards, and procedures to ensure that audit trails must be generated for all grant and revoke operations.	The CCSSA will review grant and revoke request documentation to ensure audit trails of operations exist.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	The CCSSA will request a demonstration of the grant and revoke processes to ensure audit trails are generated.	The CCSSA will interview personnel who are responsible for the grant and revoke access processes to ensure audit trails are generated.	

CCSS v9 Testing Procedures							
Requirement #	Requirement	Review		Inspect	Observe	Interview	Additional Guidance
		Policy, Standards, Procedures (PSP)	Business As Usual (BAU)				
1.05.1.1	Access to the operational key material requires an identifier and at least 2 (two) distinct types of authentication factors.	The CCSSA will review access management policies, standards, and procedures to ensure that access to operational key material requires at least two distinct authentication factors.	The review of BAU records for this requirement is not a mandatory testing procedure for a CCSS audit, but it is at the discretion of the CCSSA to conduct it.	The CCSSA will inspect the authentication mechanism configurations to ensure that all access to operational key material requires at least two distinct authentication factors.	The CCSSA will observe personnel attempting to access key material and being prompted to provide at least two distinct forms of authentication factors.	The CCSSA will interview personnel who are responsible for access management to key material to ensure that access to operational key material requires at least two distinct authentication factors.	
1.05.1.2	Access to Key Material requires an identifier (e.g., username, email, GUID) and at least 3 (three) distinct types of authentication factors.	The CCSSA will review access management policies, standards, and procedures to ensure that access to operational key material requires at least three distinct authentication factors.	The review of BAU records for this requirement is not a mandatory testing procedure for a CCSS audit, but it is at the discretion of the CCSSA to conduct it.	The CCSSA will inspect the authentication mechanism configurations to ensure that all access to operational key material requires at least three distinct authentication factors.	The CCSSA will observe personnel attempting to access key material and being prompted to provide at least three distinct forms of authentication factors.	The CCSSA will interview personnel who are responsible for access management to key material to ensure that access to operational key material requires at least two distinct authentication factors.	
1.05.2.1	Key material is only used within the CCSS Trusted Environment.	The CCSSA will review key management policies, standards, and procedures to ensure that operational key material can only be used within the CCSS Trusted Environment.	The CCSSA will review key material generation records and the key material inventory to ensure that operational key material is only used within the CCSS Trusted Environment.	The CCSSA will inspect key management systems and ensure that operational key material is only used within the CCSS Trusted Environment.	The CCSSA will request a demonstration of the usage of operational key material to ensure that key material is only used within the CCSS Trusted Environment.	The CCSSA will interview personnel responsible for ensuring that operational key material is only used within the CCSS Trusted Environment.	
1.05.2.2	The key material is isolated from other operating systems and application processes to avoid unauthorized access or leakage of key material.	The CCSSA will review key management policies, standards, and procedures to ensure that operational key material can only be used within an HSM, TEE, or equivalent.	The CCSSA will review key material generation records and the key material inventory to ensure that operational key material is only used within an HSM, TEE, or equivalent.	The CCSSA will inspect key management systems and ensure that operational key material is only used within an HSM, TEE, or equivalent.	The CCSSA will request a demonstration of the usage of operational key material to ensure that key material is only used within an HSM, TEE, or equivalent.	The CCSSA will interview personnel responsible to ensure that operational key material is only used within an HSM, TEE, or equivalent.	
1.05.2.3	The key material is isolated from other operating system and application processes to avoid unauthorized access or leakage of key material. CCSS Level 3 requires FIPS 140.	The CCSSA will review key management policies, standards, and procedures to ensure that operational key material can only be used within an HSM, TEE, or equivalent and FIPS 140-2 or FIPS 140-3 validated.	The CCSSA will review key material generation records and the key material inventory to ensure that operational key material is only used within an HSM, TEE, or equivalent and FIPS 140-2 or FIPS 140-3 validated.	The CCSSA will inspect key management systems and ensure that operational key material is only used within an HSM, TEE, or equivalent and FIPS 140-2 or FIPS 140-3 validated.	The CCSSA will request a demonstration of the usage of operational key material to ensure that key material is only used within an HSM, TEE, or equivalent and FIPS 140-2 or FIPS 140-3 validated.	The CCSSA will interview personnel responsible to ensure that operational key material is only used within an HSM, TEE, or equivalent.	
1.05.3.1	All individual actors involved in operations with key material, or with the ability to impact the security of key generation, management, or usage have had their references checked prior to the actor being trusted with access to key material or operations.	The CCSSA will review policies, standards, and procedures to ensure all personnel who will have access to key material or could impact the security of key material will have their references checked before granted access to key material.	The CCSSA will review employment records or equivalent to ensure that personnel with access to key material or who could impact the security of key material have their references checked.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	The CCSSA will request a demonstration of the reference check process to ensure reference checks are carried out using industry best practices.	The CCSSA will interview personnel who are responsible for ensuring reference checks are undertaken.	
1.05.4.1	All actors involved in operations with key material, or with the ability to impact the security of key generation, management, usage, or storage have undergone identity verification to ensure they are who they say they are. These checks are conducted prior to the actor being trusted with access to key material.	The CCSSA will review policies, standards, and procedures to ensure all personnel who will have access to key material or could impact the security of key material will have their identity checked before being granted access to key material.	The CCSSA will review employment records or equivalent to ensure that personnel with access to key material or who could impact the security of key material have their identity checked.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	The CCSSA will request a demonstration of the identity check process to ensure identity checks are carried out using industry best practices.	The CCSSA will interview personnel who are responsible for ensuring identity checks are completed.	

CCSS v9 Testing Procedures							
Requirement #	Requirement	Review		Inspect	Observe	Interview	Additional Guidance
		Policy, Standards, Procedures (PSP)	Business As Usual (BAU)				
1.05.5.1	All individual actors involved in operations with key material, or with the ability to impact the security of key generation, management, usage, or storage have had background checks performed by law enforcement personnel or investigative firms. These checks are conducted prior to the actor being trusted with access to key material or operations and periodically; as allowed by local laws and regulations.	The CCSSA will review policies, standards, and procedures to ensure all personnel who will have access to key material or could impact the security of key material will have a background check before being granted access to key material and from then on periodically.	The CCSSA will review employment records or equivalent to ensure that personnel with access to key material or who could impact the security of key material have a background check before access to key material is granted or have the ability to impact the security of key material. The CCSSA will also check to ensure that background checks are performed periodically.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	The CCSSA will request a demonstration of the background check process to ensure background checks are carried out using industry best practices.	The CCSSA will interview personnel who are responsible for ensuring background checks are completed.	
1.05.6.1	All individuals involved in key management operations, or with the ability to impact the security of Key Material, complete specific applicable training. This training is to be conducted on hire, and conducted before the actor being trusted with access to Key Material, and then annually.	The CCSSA will review policies, standards, and procedures to ensure all personnel with access to key material, or that could impact the security of key material complete applicable training.	The CCSSA will review the training material to ensure training is tailored to the person's roles and responsibilities related to key management operations. The CCSSA will review the training completion records to ensure all personnel who have access to key material or could impact the security of key material have completed the required training.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	Observation for this requirement is optional; may be used at the CCSSA's discretion.	The CCSSA will interview personnel who are responsible for maintaining the training material to ensure the training material remains relevant to the roles of the personnel undertaking the training. The CCSSA will interview personnel who are responsible for ensuring personnel who have access to key material or could impact the security of key material have completed the required training.	
1.05.7.1	Key management roles and responsibilities are formally acknowledged in writing by each person who has access to key material. This includes personnel who have been delegated key management responsibilities.	Key management roles and responsibilities are formally acknowledged in writing by each person who has access to key material. This includes personnel who have been delegated key management responsibilities.	The CCSSA will review acknowledgment records for personnel who can access key material to ensure written acknowledgement has been recorded.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	The CCSSA will request a demonstration of the process to ensure personnel who can access key material formally acknowledge their roles and responsibilities in writing.	The CCSSA will interview personnel responsible for ensuring that personnel who can access key material have formally acknowledged their roles and responsibilities in writing.	
1.05.8.1	Verification of fund destinations and amounts is performed via Approved Communication Channels prior to the use of key material.	The CCSSA will review policies, standards, and procedures to ensure destination addresses and fund amounts are required to be verified before the transaction is signed and only approved communication channels are used.	The CCSSA will review transaction records to ensure that the transaction process includes the verification of the destination address and fund amount via approved communication channels before transaction signing.	If software is used as part of the verification process, the CCSSA will inspect the verification mechanism configuration to ensure destination addresses and fund amounts are verified and only approved communication channels are used.	The CCSSA will request a demonstration of the verification process to ensure that the destination address and fund amount are verified before the transaction signing and that only approved communication channels are used.	The CCSSA will interview personnel responsible for ensuring that destination addresses and fund amounts are verified before transaction signing and only using approved communication channels.	
1.05.9.1	Key material for a wallet that implements a multi-signer mechanism is stored and used on different logical or physical devices.	The CCSSA will review policies, standards, and procedures to ensure wallets that implement a multi-signer mechanism have key material stored and used on different logical or physical devices.	The CCSSA will review wallet generation records which implement a multi-signer mechanism to ensure that key material is stored and used on different logical or physical devices.	The CCSSA will inspect the wallet generation mechanism configurations to ensure that a wallet implementing a multi-signer mechanism ensures key material is stored and used on different logical and physical devices.	The CCSSA will request a demonstration of the wallet generation process for a wallet that implements a multi-signer mechanism to ensure that key material is stored and used on different logical and physical devices.	The CCSSA will interview personnel responsible for wallet generation to ensure that a wallet implementing a multi-signer mechanism ensures key material is stored and used on different logical and physical devices.	
1.05.10.1	Digital signatures follow best practices for the algorithm(s) implemented by the Key Management System.	The CCSSA will review policies, standards, and procedures to ensure the generation and use of digital signatures follow internationally recognized standards.	The CCSSA will review digital signature generation and use records to ensure internationally recognized standards have been used.	The CCSSA will inspect the digital signature generation and usage mechanism configurations to ensure internationally recognized standards have been used.	The CCSSA will request a demonstration of the generation and use of a digital signature to ensure internationally recognized standards have been used.	The CCSSA will interview personnel responsible for the digital signature generation and usage mechanisms to ensure internationally recognized standards have been used.	

CCSS v9 Testing Procedures							
Requirement #	Requirement	Review		Inspect	Observe	Interview	Additional Guidance
		Policy, Standards, Procedures (PSP)	Business As Usual (BAU)				
1.06.1.1	The organization's staff is aware of how data persists on digital media after deletion. Staff also have access to tools that perform secure deletion of data and understand when to use such tools to permanently destroy any transient copies of cryptographic keys that may be required during the maintenance of the information system.	The CCSSA will review policies, standards, and procedures to ensure the secure sanitization and physical destruction of media containing key material is defined.	The CCSSA will review sanitization and destruction records and certificates for media containing or did contain key material to ensure the process follows the policies, standards, and procedures.	The CCSSA will inspect the tools (including software and hardware) used to perform sanitization and destruction processes. Note: If a third-party entity skilled and qualified to perform sanitization or destruction services is used then the CCSSA may choose not to inspect the tools used, relying instead on the certificate of sanitization or destruction provided by the third party.	The CCSSA will request a demonstration of the sanitization and destruction processes. Note: If a third-party entity skilled and qualified to perform sanitization or destruction services is used, then the CCSSA may choose not to observe the processes, relying instead on the certificate of sanitization or destruction provided by the third party.	The CCSSA will interview personnel responsible for ensuring sanitization and destruction processes follow the policies, standards, and procedures.	
1.06.2.1	An audit trail is maintained for every piece of sanitized media conforming to the NIST SP 800-88 recommendation. These audit documents identify personnel who performed the sanitization, the specific identifiers of the media that was sanitized, which tool and configuration was used to perform the sanitization, and all other relevant pertinent information.	The CCSSA will review policies, standards, and procedures to ensure the secure sanitization and physical destruction of media processes generates audit trails conforming to NIST SP 800-88.	The CCSSA will review sanitization and destruction records and certificates for media containing or did contain key material to ensure audit trails are generated.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	The CCSSA will request a demonstration of the sanitization and destruction processes to ensure audit trails are generated that conform to NIST SP 800-88. Note: If a third-party entity skilled and qualified to perform sanitization or destruction services is used, then the CCSSA may choose not to observe the processes, relying instead on the certificate of sanitization or destruction provided by the third party.	The CCSSA will interview personnel responsible for ensuring sanitization and destruction processes generate audit trails.	

CCSS v9 Testing Procedures							
Requirement #	Requirement	Review		Inspect	Observe	Interview	Additional Guidance
		Policy, Standards, Procedures (PSP)	Business As Usual (BAU)				
2.01.1.1	An individual with expertise in information security must be engaged in all stages of the design, development, deployment, and ongoing maintenance of systems providing cryptocurrency functions. This ensures that information security principles are integrated into every phase of the system's life cycle.	The CCSSA will review policies, standards, and procedures to ensure that individuals with information security expertise are engaged in all stages of software development and testing.	The CCSSA will review software development outputs such as design documentation and testing plans to ensure information security has been considered in all stages of software development and testing.	Inspection for this requirement is optional; may be used at the CCSSA's discretion However, the CCSSA may inspect software development and testing tooling, if used, to ensure information security principles have been included in development and testing processes.	The CCSSA will request a demonstration of how information security principles are considered during the software development and testing life cycle.	The CCSSA will interview personnel who are responsible for ensuring information security is considered at every stage of software development and testing.	
2.01.1.2	A regular security assessment that includes vulnerability and penetration testing has been completed by an independent, qualified third-party. Documentation shows that all concerns raised by the assessment have been evaluated for risk and addressed by the entity.	The CCSSA will review policies, standards, and procedures to ensure that an independent third party skilled and qualified in conducting information security assessments, including penetration testing and vulnerability scanning, is engaged to ensure that systems that provide cryptocurrency functions are as secure as possible. The CCSSA will review policies, standards, and procedures to ensure an information security assessment is conducted at least annually. The CCSSA will review policies, standards, and procedures to ensure the assessment report's findings are addressed by the entity.	The CCSSA will review information security assessments to ensure the entire CCSS Trusted Environment has been included in the assessment. The CCSSA will review information security assessments to ensure the information security assessment is conducted at least annually. The CCSSA will review information security assessments to ensure the information security assessment's findings have been addressed by the entity.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	Observation for this requirement is optional; may be used at the CCSSA's discretion.	The CCSSA will interview personnel who are responsible for the information security assessments to ensure that: The entire CCSS Trusted Environment has been included in the assessment. The information security assessment was conducted at least annually. The information security assessment's findings have been addressed by the entity.	
2.01.1.3	A regular security audit at a level similar to SOC 2, ISAE3402, or ISO 27001, that includes vulnerability, penetration testing, and code audit (if applicable) has been completed by an independent qualified third-party. Documentation shows that all concerns raised by the audit have been evaluated for risk, addressed by the entity, and known vulnerabilities have been removed from the CCSS Trusted Environment. Ongoing audits are scheduled on a (minimum) yearly basis.	The CCSSA will review policies, standards and procedures to ensure that the CCSS Trusted Environment must be audited and certified by an external and independent third-party skilled and qualified to conduct an information security audit against an international and industry-recognized standard such as ISO/IEC 27001 and PCI DSS.	The CCSSA will review the audit certifications and other audit outputs to ensure the entire CCSS Trusted Environment is included in the audit scope.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	Observation for this requirement is optional; may be used at the CCSSA's discretion.	The CCSSA will interview personnel who are responsible for ensuring that the CCSS Trusted Environment is included in the audit scope and certified against an international and industry-recognized standard such as ISO/IEC 27001, PCI DSS, and SOC 2.	
2.01.2.1	All smart contract software code versions deployed to the environment(s) where the entity stakeholders interact with the smart contract have been audited by an external third-party auditor skilled in the development languages used for the smart contract software. NOTE: the requirement is not applicable to any environments used for development, testing, or staging. This requirement applies to smart contracts deployed to the "production" network or the like.	The CCSSA will review policies, standards and procedures to ensure all smart contract software code is audited before deployment to "production."	The CCSSA will review smart contract software code audit reports and ensure that the version currently running in "production" has been audited.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	Observation for this requirement is optional; may be used at the CCSSA's discretion.	The CCSSA will interview personnel who are responsible for ensuring smart contract software code deployed to "production" has been audited.	

CCSS v9 Testing Procedures							
Requirement #	Requirement	Review		Inspect	Observe	Interview	Additional Guidance
		Policy, Standards, Procedures (PSP)	Business As Usual (BAU)				
2.01.2.2	All smart contract software code audit reports are accessible to the entity stakeholders. The audit reports cover the currently deployed versions to the environment(s) where the entity stakeholders interact with the smart contract. NOTE: the requirement is not applicable to any environments used for development, testing, or staging. This requirement applies to smart contracts deployed to the "production" network or the like.	The CCSSA will review policies, standards and procedures to ensure that the smart contract software audit reports are accessible to all stakeholders, and if any changes to the smart contract software code will trigger an audit before that version of the smart contract software code is deployed to "production." The CCSSA will review risk assessment policies, standards, and procedures to ensure the entity considers the risk of not conducting a delta or full audit if the smart contract software code is changed after an audit has been conducted.	The CCSSA will review smart contract software code audit reports and ensure that the version currently running in "production" has been audited. The CCSSA will review risk assessment outputs that resulted in the decision not to conduct another delta or full audit after changes to the software code were made after the last audit.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	Observation for this requirement is optional; may be used at the CCSSA's discretion.	The CCSSA will interview personnel who are responsible for ensuring that smart contract software code is audited before deployment to "production."	
2.01.2.3	All issues with a severity of medium or higher identified in a code audit of the smart contract software are addressed by the entity before deployment to the environment (s) where the entity stakeholders interact with the smart contract. NOTE: the requirement is not applicable to any environments used for development, testing, or staging. This requirement applies to smart contracts deployed to the "production" network or the like.	The CCSSA will review policies, standards, and procedures to ensure that the smart contract software code audit reports that identified issues with a severity ranking of medium and above must be addressed before deployment to production.	The CCSSA will review remediation outputs to ensure that all issues identified as medium and higher have been remediated before the smart contract software code is deployed to "production."	Inspection for this requirement is optional; may be used at the CCSSA's discretion	Observation for this requirement is optional; may be used at the CCSSA's discretion.	The CCSSA will interview personnel who are responsible for ensuring that issues identified within the smart contract software code audit report with a ranking of medium and higher are remediated before deployment to "production."	

CCSS v9 Testing Procedures							
Requirement #	Requirement	Review		Inspect	Observe	Interview	Additional Guidance
		Policy, Standards, Procedures (PSP)	Business As Usual (BAU)				
2.02.1.1	Audit trails exist for a subset of actions performed within the CCSS Trusted Environment.	The CCSSA will review policies, standards, and procedures to ensure that log event records are generated for all technical components within the CCSS Trusted Environment. The CCSSA will review policies and procedures to ensure the events to be logged are based on the threat modelling in requirement 2.03.2.1.	The CCSSA will review log event records to ensure that the defined events to generate logs are being generated.	The CCSSA will inspect the logging mechanism configurations to ensure that the defined events to generate logs are being generated.	Observation for this requirement is optional; may be used at the CCSSA's discretion.	The CCSSA will interview personnel who are responsible for ensuring the events to be logged are logged.	
2.02.1.2	All actions performed by all users within the CCSS Trusted Environment are logged. Audit logs are retained for at least one year in a trusted environment.	The CCSSA will review policies, standards, and procedures to ensure that log event records are generated for all actions performed by personnel within the CCSS Trusted Environment and that log event records are retained in a trusted environment for at least one year.	The CCSSA will review log event records to ensure that all actions performed by personnel within the CCSS Trusted Environment generate log event records. The CCSSA will review log event records to ensure the retention period is at least one year after the log event record has been generated.	The CCSSA will inspect the logging mechanism configurations to ensure that all events performed by personnel within the CCSS Trusted Environment generate log event records. The CCSSA will inspect the logging mechanism configurations to ensure that log event records are retained for at least one year after generation.	Observation for this requirement is optional; may be used at the CCSSA's discretion.	The CCSSA will interview personnel who are responsible for ensuring all events performed by personnel within the CCSS Trusted Environment generate log event records and log event records are retained for at least one year after generation.	
2.02.2.1	In addition to recording all actions performed within the CCSS Trusted Environment, this audit information is periodically backed up to a separate server.	The CCSSA will review policies, standards, and procedures to ensure all log event records generated within the CCSS Trusted Environment are periodically backed up to a separate server. The CCSSA will review policies and procedures to ensure the backed-up log event records cannot be edited or deleted.	The CCSSA will review backed-up log event records to ensure all original log event records have been periodically backed up.	The CCSSA will inspect the logging mechanism configurations to ensure all log event records are periodically backed up. The CCSSA will inspect the logging mechanism configurations to ensure all backed up log event records cannot be edited or deleted.	Observation for this requirement is optional; may be used at the CCSSA's discretion.	The CCSSA will interview personnel who are responsible for ensuring all log event records generated within the CCSS Trusted Environment are periodically backed up to a separate server and all backed-up log event records cannot be edited or deleted.	
2.02.2.2	In addition to recording all actions performed within the CCSS Trusted Environment, this audit information is continually backed up to a separate server.	The CCSSA will review policies, standards, and procedures to ensure all log event records generated within the CCSS Trusted Environment are continually backed up to a separate server. The CCSSA will review policies and procedures to ensure the backed-up log event records cannot be edited or deleted.	The CCSSA will review backed-up log event records to ensure all original log event records have been continually backed up.	The CCSSA will inspect the logging mechanism configurations to ensure all log event records are continually backed up. The CCSSA will inspect the logging mechanism configurations to ensure all backed up log event records cannot be edited or deleted.	Observation for this requirement is optional; may be used at the CCSSA's discretion.	The CCSSA will interview personnel who are responsible for ensuring all log event records generated within the CCSS Trusted Environment are continually backed up to a separate server and all backed-up log event records cannot be edited or deleted.	
2.02.3.1	The CCSS Trusted Environment's audit logs are monitored for suspicious activity, and alerts are generated when suspicious activity is detected. Appropriate personnel address the alerts generated. The monitoring frequency is defined by the entity and meets all components of requirement 2.03.2.1.	The CCSSA will review policies, standards, and procedures to ensure log event records are monitored for defined events and appropriate personnel alerted. The CCSSA will review policies, standards and procedures to ensure that monitoring frequency has been defined from the outputs of requirement 2.03.2.1. The CCSSA will review policies, standards and procedures to ensure that the required roles and skill sets of the appropriate personnel to receive monitoring alerts are defined.	The CCSSA will review alerting event records to ensure alerts are generated for the defined events. The CCSSA will review the list of appropriate personnel receiving monitoring alerts to ensure that each person is appropriate for this role and their skill set.	The CCSSA will inspect the monitoring and alerting mechanism configurations to ensure all defined events are monitored for events. The CCSSA will inspect the monitoring and alerting mechanism configurations to ensure appropriate personnel are alerted when a defined event is detected.	The CCSSA will request a demonstration of personnel receiving alerts and conducting appropriate incident response processes.	The CCSSA will interview personnel who are responsible for ensuring the defined events are monitored and that appropriate personnel are alerted to the detection of defined events.	

CCSS v9 Testing Procedures							
Requirement #	Requirement	Review		Inspect	Observe	Interview	Additional Guidance
		Policy, Standards, Procedures (PSP)	Business As Usual (BAU)				
2.02.3.2	The CCSS Trusted Environment's audit logs are continuously monitored for suspicious activity, and alerts are generated in real time when suspicious activity is detected. Appropriate personnel address the alerts generated.	The CCSSA will review policies, standards, and procedures to ensure log event records are continuously monitored for defined events and appropriate personnel alerted. The CCSSA will review policies, standards, and procedures to ensure that the required roles and skill sets of the appropriate personnel to receive monitoring alerts are defined.	The CCSSA will review alerting event records to ensure alerts are generated for the defined events. The CCSSA will review the list of appropriate personnel receiving monitoring alerts to ensure that each person is appropriate for this role and their skill set.	The CCSSA will inspect the monitoring and alerting mechanism configurations to ensure all defined events are continuously monitored for events. The CCSSA will inspect the monitoring and alerting mechanism configurations to ensure appropriate personnel are alerted when a defined event is detected.	The CCSSA will request a demonstration of personnel receiving alerts and conducting appropriate incident response processes.	The CCSSA will interview personnel who are responsible for ensuring the defined events are monitored and that appropriate personnel are alerted to the detection of defined events.	
2.02.4.1	Relevant blockchain state (confirmed and unconfirmed) as it relates to the CCSS Trusted Environment are continuously monitored for anomalous behavior, generating alerts. Appropriate personnel address the alerts that are generated.	The CCSSA will review policies, standards, and procedures to ensure that monitoring a blockchain's relevant confirmed and unconfirmed states is required.	The CCSSA will review outputs of the monitoring mechanism such as event records to ensure the relevant blockchain confirmed and unconfirmed state is monitored.	The CCSSA will inspect the mechanism configurations that monitor relevant confirmed and unconfirmed blockchain states to ensure the relevant blockchain confirmed and unconfirmed state is monitored.	Observation for this requirement is optional; may be used at the CCSSA's discretion.	The CCSSA will interview personnel who are responsible for the monitoring of relevant confirmed and unconfirmed blockchain states to ensure this requirement's intent is met.	

CCSS v9 Testing Procedures							
Requirement #	Requirement	Review		Inspect	Observe	Interview	Additional Guidance
		Policy, Standards, Procedures (PSP)	Business As Usual (BAU)				
2.03.1.1	A member of executive management is responsible for the security of the system and formally acknowledges their responsibilities in writing.	The CCSSA will review policies, standards, and procedures to ensure that executive management formally acknowledges their responsibility for the CCSS Trusted Environments' information security program. The CCSSA will review policies, standards, and procedures to ensure that the following is addressed for the entity's information security program: 1. Ensuring information security policies, standards and procedures are in place, known and used. 2. Resources are properly allocated to the CCSS Trusted Environment's information security program. 3. Security awareness is promoted throughout the entity. 4. Continuous improvement of the system's information security program is driven.	The CCSSA will review executive management's signed acknowledgement records to ensure at least one member of executive management is responsible for the CCSS Trusted Environments information security program. The CCSSA will review the outputs of the processes that support this requirement's defined responsibilities to ensure: 1. Information security policies and procedures are in place. 2. Resources are properly allocated to the CCSS Trusted Environment's information security program. 3. Security awareness is promoted throughout the entity. 4. Continuous improvement of the system's security program is driven.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	Observation for this requirement is optional; may be used at the CCSSA's discretion.	The CCSSA will interview personnel who are responsible for ensuring that executive management formally acknowledges their information security responsibilities for the CCSS Trusted Environment. The CCSSA will interview personnel who are responsible for ensuring that the responsibilities defined within this requirement are implemented and met.	
2.03.2.1	The entity has identified security threats to the CCSS Trusted Environment and have defined and implemented controls to reduce the residual risk of an attack to an acceptable level using a threat model. The following considerations are addressed: 1. The entity reviews the threat model periodically to ensure it is up-to-date, the controls currently implemented are still effective, and the risk of an attack is reduced. 2. If a procedure requires a defined frequency to perform tasks for a control, such as reviewing audit logs, the threat model specifies the task frequency.	The CCSSA will review policies, standards, and procedures to ensure that a threat model program must be implemented. The CCSSA will review policies and procedures to ensure that the following are addressed by the entity's threat modelling processes: 1. The entity reviews the threat model periodically to ensure it is up-to-date, the controls currently implemented are still effective, and the risk of an attack is reduced. 2. If a procedure requires a defined frequency to perform tasks for a control, such as reviewing audit logs, the threat model specifies the task frequency.	The CCSSA will review the outputs of the threat modelling processes to ensure the defined considerations are met: 1. The entity reviews the threat model periodically to ensure it is up-to-date, the controls currently implemented are still effective, and the risk of an attack is reduced. 2. If a procedure requires a defined frequency to perform tasks for a control, such as reviewing audit logs, the threat model specifies the task frequency.	The CCSSA will inspect the information security controls identified from the outputs of the threat modelling to ensure that the information security controls have been implemented.	The CCSSA will observe appropriate personnel conduct threat modelling processes to ensure the threat modelling processes have been implemented.	The CCSSA will interview personnel who are responsible for ensuring thread modelling has been implemented. The CCSSA will interview personnel who are responsible for ensuring all considerations defined within this requirement have been implemented.	
2.03.2.2	The entity implements a risk management program based on industry recognized risk management standards and frameworks such as ISO/IEC 27005 and NIST SP 800-37.	The CCSSA will review policies, standards, and procedures to ensure that the risk management program aligns with industry recognized risk management standards.	The CCSSA will review the outputs of risk management processes to ensure information security risks have been identified and managed using industry recognized risk management standards.	The CCSSA will inspect the information security controls identified from the outputs of the risk management processes to ensure that the information security controls have been implemented.	The CCSSA will observe appropriate personnel conduct risk management processes to ensure the risk management processes align with industry recognized risk management standards.	The CCSSA will interview personnel who are responsible for ensuring the risk management program aligns with industry recognized risk management standards.	

CCSS v9 Testing Procedures							
Requirement #	Requirement	Review		Inspect	Observe	Interview	Additional Guidance
		Policy, Standards, Procedures (PSP)	Business As Usual (BAU)				
2.03.3.1	Requirement: Service provider management is implemented for any vendor or service provider that could impact the security of the CCSS Trusted Environment and addresses: 1. Procurement processes to ensure any vendor or service provider meets applicable CCSS requirements before contractual engagement. 2. Annual review of the vendor or service provider's compliance with applicable CCSS requirements. The frequency of review may increase from at least annually based on the entity threat model as defined in requirement 2.03.2.1.	The CCSSA will review policies and procedures to ensure that service provider management is required and includes: 1. A risk assessment of the potential service provider or vendor's impact on the security of the CCSS Trusted Environment. 2. An annual review of the service provider or vendor's impact on the security of the CCSS Trusted Environment. 3. If the risk assessment identifies that the service provider or vendor poses a significant risk to the security of the CCSS Trusted Environment, the review frequency is increased based on the outputs of the threat modelling and risk assessment performed for requirements 2.03.2.1 and 2.03.2.2.	The CCSSA will: 1. Review the outputs of the threat modelling, risk assessment, and procurement processes for any new service providers or vendors engaged in the CCSS audit testing period. 2. Annual (or more frequent) reviews of existing service providers and vendor's information security posture to ensure the impact on the security of the CCSS Trusted Environment the service provider or vendor poses is acceptable.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	The CCSSA will request a demonstration of the procurement and review processes for ensuring a service provider or vendor risks to the security of the CCSS Trusted Environment are at acceptable levels of risk	The CCSSA will interview personnel who are responsible for ensuring service provider management is implemented and meets the intent of this requirement.	

CCSS v9 Testing Procedures							
Requirement #	Requirement	Review		Inspect	Observe	Interview	Additional Guidance
		Policy, Standards, Procedures (PSP)	Business As Usual (BAU)				
2.04.1.1	An inventory of all key material exists and the entity has an awareness of which key material is critical to the successful operation of the CCSS Trusted Environment.	The CCSSA will review policies, standards, and procedures to ensure that a key material inventory is required.	The CCSSA will review the key material inventory to ensure the key material inventory exists and records all critical key material.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	The CCSSA will request a demonstration of the process for updating the key material inventory to ensure that the policies, standards, and procedures for updating the key material inventory are followed.	The CCSSA will interview personnel who are responsible for ensuring that a key material inventory exists.	
2.04.1.2	A Key Compromise Policy and procedures are documented that detail: each specific classification of key material used throughout the CCSS Trusted Environment; a detailed plan of dealing with its compromise that includes the use of Approved Communication Channels during execution; identities of actors via roles (not names), and includes secondary actors in the event any primary actor is unavailable to carry out the KCP.	The CCSSA will review policies, standards, and procedures to ensure that a key compromise response plan addresses all the criteria stated in this requirement. The CCSSA will review the key compromise response plan to ensure all criteria stated by this requirement are addressed.	If a key compromise incident occurred within the CCSS audit testing period, the CCSSA will review the key compromise incident response outputs, such as incident reports.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	The CCSSA will request a demonstration of the key compromise incident response process to ensure all criteria stated by this requirement are addressed.	The CCSSA will interview personnel who are responsible for ensuring a key compromise plan addresses all criteria stated by this requirement.	
2.04.1.3	The key material inventory is reviewed at least annually to ensure that all key material has been recorded and that the recorded information for key material is accurate and up-to-date.	The CCSSA will review policies, standards, and procedures to ensure that the key material inventory must be reviewed at least annually.	The CCSSA will review the outputs of the key material inventory review process to ensure the key material inventory has been reviewed at least annually.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	The CCSSA will request a demonstration of the process for reviewing the key material inventory to ensure that the policies and procedures for reviewing the key material inventory are followed.	The CCSSA will interview personnel who are responsible for ensuring that a key material inventory is reviewed at least annually.	
2.04.2.1	The Key Compromise Policy and procedures are tested at least annually to ensure their viability and to ensure personnel remain trained to use them in the event of a compromise. The following is addressed: 1. The testing exercise is documented and includes the attendees, scenarios tested, outcomes of testing, remediation required, actions, and the next testing date. 2. Any improvements identified from the test are updated in the Key Compromise Policy and procedures. 3. The testing includes ensuring backup(s) containing key material are reviewed and tested where applicable. 4. Any changes to the system's people, processes, and technology components trigger a test of the Key Compromise Policy and procedures.	The CCSSA will review policies, standards, and procedures to ensure that the key compromise plan is: 1. Tested at least annually, or if the outputs of the threat modelling and risk assessment identify high risks to the security of the CCSS Trusted Environment, then increasing the frequency of testing should be considered and documented by the entity. 2. The testing addresses all the requirements criteria. 3. There is a plan to test all scenarios identified by the outputs of the threat modelling and risk assessment.	The CCSSA will review the outputs of the key compromise plan testing to ensure that at least one test of the key compromise plan has been undertaken within the CCSS audit testing period and that all criteria for this requirement were addressed.	Inspection for this requirement is optional; may be used at the CCSSA's discretion	The CCSSA will request a demonstration of the key compromise plan testing to ensure all criteria for this requirement have been met.	The CCSSA will interview personnel who are responsible for ensuring that the key compromise plan is tested at least annually or based on the outputs of the threat modelling and risk assessment.	